TODO API Input Validation Report

Summary: The POST /todos endpoint accepts any request body without validation. This report documents the risks and a remediation plan using schema validation and unit tests.

Page 2 of 4 - Findings

Finding 1: title is not required and may be empty.

Finding 2: dueAt accepts arbitrary strings instead of ISO dates.

Finding 3: clients can overwrite id and done fields.

Severity: high. All three issues are reachable from the public API.

Introduce a zod (Node) or pydantic (Python) schema for the body.
Reject invalid bodies with HTTP 400 and a structured issues array.
Strip client-provided id and done before persisting.
Estimated effort: half a day including tests.

Add four unit tests: empty title, oversized title, invalid dueAt,
and a test proving a client-provided id is ignored.
Run the suite in CI on every pull request.
Owner: backend team. Target: next sprint.